

DIAMOND HANDS HOLDING INC.

TO: Jake Bulim, Evan Battaglia, John Smith, Steve Smith, Katie Tylerr

FROM: Chander Blount, Ethan Byrd, Hatice Bulut

SUBJECT: Governance Design Report

DATE: December 08, 2025

Dear Executives and Stakeholders,

The attached Governance and Staffing Program Design Report has been developed to evaluate the current cybersecurity governance posture of Diamond Hands Holding Inc. (DHHI) and propose a structured roadmap to improve oversight, accountability, and operational resilience.

This report outlines a series of phased initiatives focused on the creation, implementation, and long-term sustainment of a cybersecurity governance framework aligned with NIST CSF, ISO/IEC 27001, and industry best practices. These initiatives include governance policy development, formal role definition, implementation of a Governance, Risk, and Compliance (GRC) platform, and the establishment of measurable performance and compliance reporting mechanisms.

Additionally, the report includes a comprehensive staffing analysis that identifies the organizational capacity required to support governance maturity. A phased hiring and workforce development plan is included, along with a forecasted three-year budget for governance activities and personnel investments. Together, these recommendations present a scalable approach that balances operational feasibility with compliance requirements and long-term cybersecurity strategy.

We appreciate your review and look forward to discussing next steps, prioritization, and implementation timelines.

Sincerely,
Chandler Blount, Ethan Byrd, Hatice Bulut
Cybersecurity Process Consultants

A report prepared in partial completion of
The CYBR 7930 Capstone course

Governance Program Design

Chandler Blount, Ethan Byrd, Hatice Bulut

December 8, 2025

Table of Contents

Executive Summary 1

Problem Statement..... 1

Scope 1

Vision and Mission 1

Current State of Security Governance 2

Governance Improvement..... 3

Governance Budget Summary 5

Staffing..... 5

 Staffing Needs..... 5

 Staffing Improvement..... 6

 Staffing Budget..... 7

Staffing Budget Summary 7

Discussion 8

Conclusion 8

AI/LLM Usage Statement Error! Bookmark not defined.

Executive Summary

This Governance Program Design Report presents a comprehensive framework for strengthening Diamond Hands Holding Inc.'s (DHHI) cybersecurity governance capabilities. As the organization continues to scale across business units, cloud services, and regulatory domains, the absence of a unified governance structure introduces operational inconsistencies, accountability gaps, and elevated cyber risk. This report proposes a formalized governance model aligned with NIST Cybersecurity Framework (CSF), ISO/IEC 27001, and DHHI's strategic objectives.

The proposed Governance Program establishes leadership roles, defines oversight mechanisms, and integrates enterprise-wide cybersecurity decision-making into the company's operational model. It addresses current deficiencies, recommends a maturity-driven governance roadmap, and introduces measurable performance indicators. Additionally, the report outlines staffing requirements and a multi-year budget plan to operationalize governance, ensure regulatory alignment, and support business continuity.

This design positions DHHI to improve compliance readiness, reduce enterprise risk, and strengthen executive visibility into cybersecurity performance

Problem Statement

Diamond Hands Holding Inc. currently operates without a fully defined cybersecurity governance structure, resulting in inconsistent policies, unclear accountability, and limited executive insight into cyber risk. Governance activities are fragmented across departments, and there is no standardized process for policy creation, review, or enforcement. As the company expands, this lack of coordinated governance increases operational, regulatory, and reputational risk. A formal governance program is required to provide structure, ensure alignment with organizational goals, and establish clear responsibilities for managing cybersecurity across the enterprise.

Scope

This report covers all business units, information systems, and personnel within Diamond Hands Holding Inc. It defines an enterprise-wide governance framework that guides policy development, oversight, risk management, and compliance activities. The content is intended for executive leadership, security management, and departmental stakeholders who rely on consistent governance to support decision-making. While this report outlines strategic direction rather than detailed procedures, it establishes the foundation for future policies, standards, and operational runbooks across the organization.

Vision and Mission

The mission of Diamond Hands Holding Inc.'s cybersecurity governance program is to protect the organization's people, data, and systems through clear policies, accountable leadership, and risk-based decision-making. The program exists to ensure that security practices consistently support business operations, regulatory requirements, and the trust of clients and partners. The

long-term vision is to build a mature, resilient, and transparent security governance structure that enables DHHI to anticipate threats, adapt to emerging risks, and operate with confidence. Through continuous improvement, strong executive oversight, and alignment with industry standards, the governance program aims to create an environment where cybersecurity is integrated into every aspect of the organization's strategy and culture.

Current State of Security Governance

The current state of security governance at Diamond Hands Holding Inc. (DHHI) remains fragmented, inconsistently enforced, and lacking in centralized oversight. While the organization maintains individual security procedures and isolated technical controls, there is no comprehensive, enterprise-level Cybersecurity Program Policy (CPP) in place to define authority, assign responsibilities, or unify operational practices. Most decisions related to security risk management are reactive and driven by immediate issues rather than guided by a structured governance framework. Documentation is limited, policy ownership is unclear, and existing Issue-Specific Security Policies (ISSPs) are either incomplete, outdated, or nonexistent. As a result, business units interpret security expectations differently, leading to uneven compliance, inconsistent training, inefficiencies during incidents, and gaps in regulatory alignment.

The preferred future state is a fully mature, integrated governance environment supported by formalized policies, defined roles and responsibilities, and a clear chain of accountability extending from the Board of Directors to technical teams. Governance will be aligned with NIST CSF, ISO/IEC 27001, and NIST SP 800-53, ensuring that security decisions support both business strategy and legal requirements. The future model includes routine training, annual policy review cycles, centralized reporting dashboards, defined exception processes, and measurable controls. Leadership will receive regular risk and compliance updates to ensure informed decision-making and continuous oversight.

Progress toward this future state will be tracked through metrics such as:

- **Policy Coverage Rate:** Percentage of required CPP and ISSPs published and approved.
- **Policy Review Compliance:** Percentage of policies reviewed and updated annually.
- **Training Completion Rates:** Employee completion of required governance and security training.
- **Audit Findings:** Reduction in governance-related audit observations over time.
- **Exception Management Metrics:** Number of active exceptions, average lifecycle, and compensating controls.
- **Reporting Frequency:** Regularity and quality of governance reporting delivered to the Executive Steering Committee.

These metrics establish a measurable, repeatable process for assessing governance maturity and ensuring DHHI achieves its long-term cybersecurity objectives.

Governance Improvement

The Governance Development Program will follow a phased, interconnected roadmap to establish a mature and sustainable cybersecurity governance ecosystem across Diamond Hands Holding Inc. (DHHI). The program is designed around six coordinated project initiatives, each contributing measurable maturity progress in alignment with NIST CSF, ISO 27001, and internal business priorities.

Phase 1: Governance Foundation and Chartering (Months 1–6)

Objectives: Formalize governance authority, structure, and expectations.

Deliverables:

- Cybersecurity Governance Charter
- Governance RACI matrix
- Cybersecurity Program Policy (CPP)

Budget Estimate: \$55,000

(Covering facilitation, documentation support, and governance framework consulting)

Phase 2: Policy Development and Lifecycle Management (Months 6–12)

Objectives: Establish complete policy coverage for security operations.

Deliverables:

- Full suite of Issue-Specific Security Policies (ISSPs)
- Formal policy approval workflows and retention standards

Budget Estimate: \$80,000

Phase 3: Governance Tools and Reporting Enablement (Year 2)

Objectives: Implement governance workflow automation and reporting capabilities.

Deliverables:

- Governance, Risk, and Compliance (GRC) platform licensing and implementation
- Automated compliance dashboards
- Exception and control monitoring system

Budget Estimate: \$120,000 upfront + \$45,000 annual licensing

Phase 4: Audit and Assurance Framework (Year 2–3)

Objectives: Establish audit schedules, tracking mechanisms, and corrective action workflows.

Deliverables:

- Internal audit calendar
- External verification schedule
- Corrective Action Plan (CAP) tracking

Budget Estimate: \$55,000 annually

Phase 5: Governance Training and Awareness Program (Year 3)

Objectives: Establish mandatory training across roles and responsibilities.

Deliverables:

- Role-based governance training modules
- Leader briefings and compliance accountability checkpoints

Budget Estimate: \$30,000 annually

Phase 6: Governance Maturity Assessment and Optimization (Year 3+)

Objectives: Measure governance against NIST CSF maturity tiers and ISO alignment.

Deliverables:

- Governance Maturity Scorecard
- Updated continuous improvement roadmap

Budget Estimate: \$25,000 annually

Governance Budget Summary

Governance Phase / Initiative	Year 1	Year 2	Year 3	Three-Year Total
Phase 1: Governance Foundation & Chartering	\$55,000	—	—	\$55,000
Phase 2: Policy Development & Lifecycle Management	\$80,000	—	—	\$80,000
Phase 3: GRC Platform and Reporting Enablement	\$120,000	\$45,000	\$45,000	\$210,000
Phase 4: Audit & Assurance Framework	—	\$55,000	\$55,000	\$110,000
Phase 5: Governance Training & Awareness Program	—	—	\$30,000	\$30,000
Phase 6: Governance Maturity Assessment & Optimization	—	—	\$25,000	\$25,000
Annual Total	\$255,000	\$100,000	\$155,000	\$510,000

Figure 1

The projected governance budget reflects a scalable investment model designed to establish, operationalize, and sustain cybersecurity governance maturity over a three-year period. Costs increase as capability expands and then stabilize as programs transition from implementation to maintenance and continuous improvement cycles.

This budget demonstrates a front-loaded investment profile in policy development and program establishment, followed by recurring operational funding for licensing, audits, maturity assessments, and governance-focused workforce enablement.

Staffing

Staffing Needs

To support the governance model and ensure security practices are aligned with operational requirements, DHHI will need both expanded staffing capacity and clearly defined role functions. As cybersecurity responsibilities scale, staffing must address compliance, monitoring, risk reporting, and operational execution.

Key staffing areas impacted include:

- Governance & Compliance
- Risk Management
- Monitoring & Detection (SOC)
- Documentation and Training Support

HR will support:

- Role creation and job descriptions
- Competency and certification pathways
- Background screening and compliance validation
- Performance and accountability structure tied to governance metrics

Category	Year 1	Year 2	Year 3	Total
Salaries and Benefits	\$360,000	\$420,000	\$480,000	\$1,260,000
Certifications & Training	\$20,000	\$25,000	\$30,000	\$75,000
Tools & Licenses	\$15,000	\$15,000	\$15,000	\$45,000
Recruiting & Onboarding	\$10,000	\$10,000	\$5,000	\$25,000

Figure 2

Staffing Improvement

A phased approach will be used to hire, develop, and mature the cybersecurity workforce.

Phase 1: Role Definition and Onboarding (Months 1–6)

- Develop job descriptions and career paths
- Hire Governance Manager and Security Analyst

Budget: \$150,000 (salary allocation)

Phase 2: Capacity Expansion (Months 6–12)

- Hire Compliance Analyst and Security Engineer
- Implement training pathways and certification sponsorship

Budget: \$210,000 + \$20,000 certification funds

Phase 3: Workforce Skills Maturity (Year 2–3)

- Implement succession planning and mentorship
- Cross-train operations and governance personnel

Budget: \$70,000 per year***Phase 4: Workforce Optimization (Year 3+)***

- Align staffing ratios with operational metrics
- Introduce leadership track roles for governance and compliance

Budget: \$15,000 for career pathway infrastructure**Staffing Budget**

Category	Year 1	Year 2	Year 3	Total
Salaries and Benefits	\$360,000	\$420,000	\$480,000	\$1,260,000
Certifications & Training	\$20,000	\$25,000	\$30,000	\$75,000
Tools & Licenses	\$15,000	\$15,000	\$15,000	\$45,000
Recruiting & Onboarding	\$10,000	\$10,000	\$5,000	\$25,000

*Figure 3***Staffing Budget Summary**

The three-year budget forecast reflects the investment required to fully deploy, operationalize, and sustain the cybersecurity governance and staffing strategy at Diamond Hands Holding Inc. (DHHI). The forecast incorporates personnel growth, workforce development, operational tooling, and recruitment overhead aligned to the phased implementation plan.

The financial requirements scale deliberately over the three-year period to reflect phased hiring, capability expansion, and organizational maturity progression. Year one prioritizes foundational staffing and baseline competency building. Year two reflects capacity expansion and integration of structured development pathways. Year three represents stabilization, optimization, and leadership progression.

This investment supports the organization's shift from a reactive cybersecurity posture to a fully governed and strategically aligned security capability. Spending increases year-over-year to support staffing growth, improved skill maturity, and specialized technical competencies required to operate within the proposed governance model.

The projected three-year total investment is \$1,405,000, representing the required organizational commitment to ensure staffing capacity, competency development, policy alignment, operational readiness, and long-term governance sustainability.

Projected Costs

Category	Year 1	Year 2	Year 3	Three-Year Total
Salaries and Benefits	\$360,000	\$420,000	\$480,000	\$1,260,000
Certifications & Training	\$20,000	\$25,000	\$30,000	\$75,000
Tools & Licenses	\$15,000	\$15,000	\$15,000	\$45,000
Recruiting & Onboarding	\$10,000	\$10,000	\$5,000	\$25,000
Annual Total	\$405,000	\$470,000	\$530,000	\$1,405,000

Figure 4

Discussion

While the proposed staffing and governance roadmap follows a structured and strategic approach, leadership may consider alternative models depending on resource constraints and business priorities. Options include outsourcing portions of security operations through a managed service provider (MSP), delaying GRC automation until compliance demand intensifies, or prioritizing risk management staffing before technical roles.

Each option introduces different tradeoffs in cost, maturity speed, and long-term operational ownership.

Conclusion

The recommended improvements to cybersecurity governance and staffing provide DHHI with a scalable and resilient framework that aligns with business growth and industry expectations. By establishing clear oversight structures, refining policies, expanding staffing capabilities, and investing in continuous improvement, the organization will strengthen its risk posture, regulatory readiness, and operational consistency. When implemented, this plan will transition DHHI from

a fragmented cybersecurity environment to a structured, measurable, and strategically governed program aligned with modern security standards and business objectives.